

시큐어코딩



SW개발보안 국외기준

- 01 국외 개발보안 현황
- 02 OWASP TOP 10
- 03 CVE
- 04 CWE Top 25



학습 목표

- ✓ 국외 소프트웨어 개발보안 기준을 이해한다.
- ✓ OWASP TOP 10 을 이해하고 개발단계에 어떻게 적용할 수 있는지 이해한다.
- ✓ CVE 용도를 이해하고 개발단계에 어떻게 적용할 수 있는지 이해한다.
- ✓ CWE 용도를 이해하고, CWE TOP 25 를 개발단계에 어떻게 적용할 수 있는지 이해한다.

학습 내용

1. 국외 개발보안 현황

2. OWASP TOP 10

3. CVE

4. CWE TOP 25



SW개발보안 국외기준

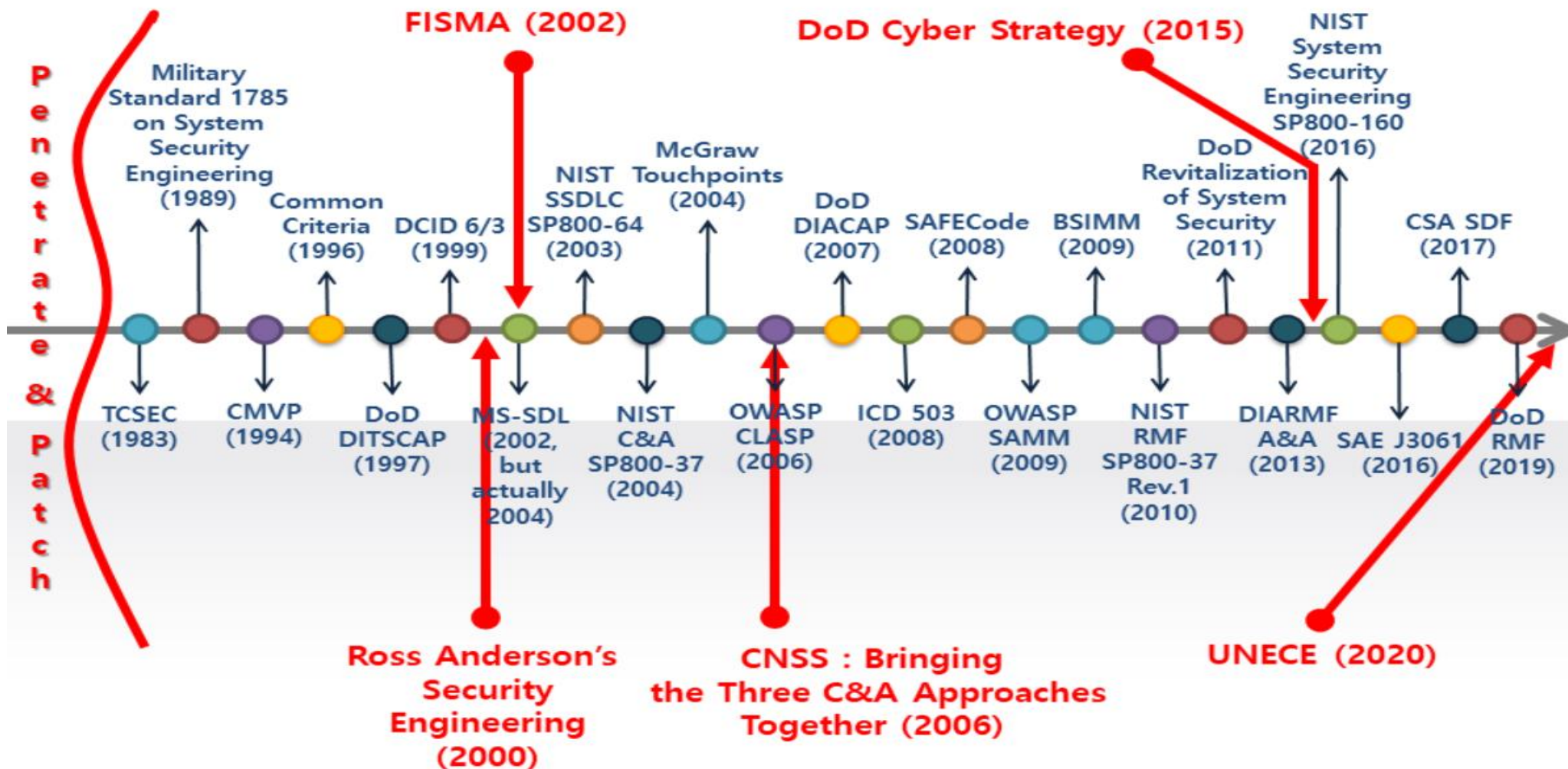
01 국외 개발보안 현황

02 OWASP TOP 10

03 CVE

04 CWE Top 25

국외 개발보안 현황



국외 개발보안 현황

국외에서는 소프트웨어 개발보안을 강화하기 위해 다양한 표준과 지침이 마련되어 있음.

NIST의 안전한 소프트웨어 개발 프레임워크(SSDF) - 미국

소프트웨어 개발 생명주기 전반에 걸쳐 보안 관행을 통합하기 위한 지침을 제공하며, 주요내용은 다음과 같음.

- 정의: 소프트웨어 개발 초기 단계에서 보안 요구사항을 명확히 정의하여 보안을 설계에 반영
- 위험 식별 및 관리: 빌드 시스템을 포함한 개발 환경의 보안 위험을 식별하고 적절한 보안 통제를 구현
- 자동화 도구 활용: 코드의 무결성을 확보하기 위해 자동화된 도구를 도입하여 정적 및 동적 분석을 수행
- 소프트웨어 구성요소 검토: 사용되는 라이브러리나 패키지 등의 구성요소에 알려진 취약점이 있는지 검사

국외 개발보안 현황

NIS2 지침 - 유럽연합(EU)

NIS2(Network and Information Security Directive 2)는 디지털 인프라를 보호하고 사이버 공격에 대한 대응력을 높이기 위한 공통의 사이버 보안 수준을 구축하는 것을 목표로 함. SW개발보안과 관련하여 조직이 다음과 같은 조치를 취하도록 요구함.

- 위험 분석 및 정보 시스템 보안 정책 수립: 조직은 정기적인 위험 분석을 수행하고, 이를 기반으로 정보 시스템 보안 정책을 수립
- 사고 대응 및 위기 관리: 사이버 사고 발생 시 신속하게 대응하고, 비즈니스 연속성을 유지하기 위한 위기 관리 계획 마련
- 공급망 보안 강화: 공급업체 및 서비스 제공자와의 관계에서 보안 요구 사항을 명확히 하고 관리
- 네트워크 및 정보 시스템의 보안 유지: 시스템의 개발 및 유지보수 과정에서 보안을 고려하고, 취약점 관리 절차 도입



SW개발보안 국외기준

01 국외 개발보안 현황

02 OWASP TOP 10

03 CVE

04 CWE Top 25

OWASP TOP 10 (<https://owasp.org/www-project-top-ten/>)

OWASP(Open Web Application Security Project)는 웹 애플리케이션의 보안 강화를 위해 가장 치명적인 보안 취약점 10가지를 정리한 OWASP Top 10을 주기적으로 발표. 웹 개발자, 보안 전문가 및 조직이 보안 위협을 예방하는데 중요한 지침으로 활용

 PROJECTS CHAPTERS EVENTS ABOUT

Search OWASP.org 

Donate Join

OWASP Top Ten

[Main](#) [Translation_Efforts](#) [Sponsors](#) [Data_2020](#)

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

Globally recognized by developers as the first step towards more secure coding.

Companies should adopt this document and start the process of ensuring that their web applications minimize these risks. Using the OWASP Top 10 is perhaps the most effective first step towards changing the software development culture within your organization into one that produces more secure code.

Watch 46 Star 139

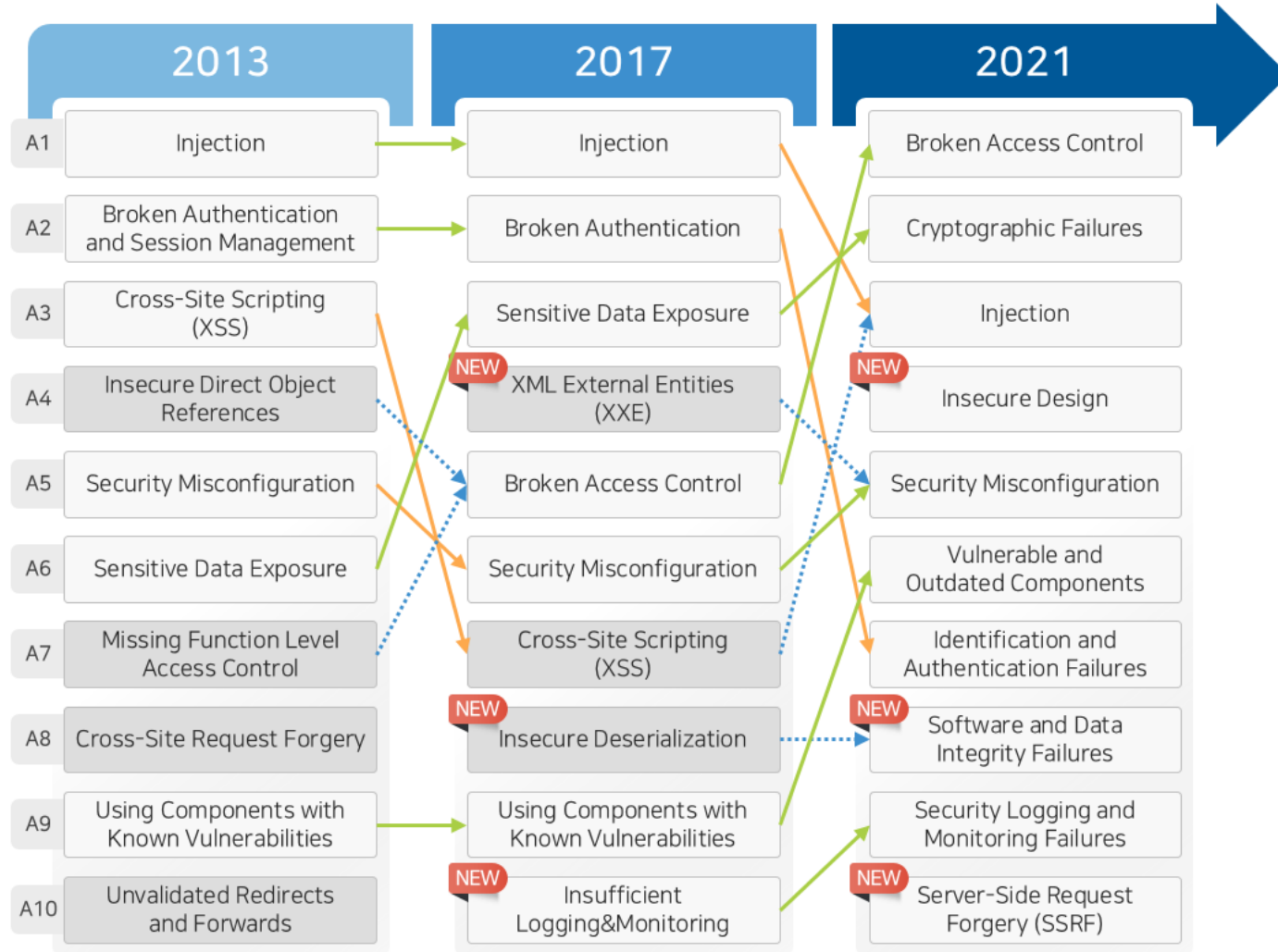
The OWASP Foundation works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

Project Information

-  Flagship Project
-  Documentation
-  Builder
-  Defender

[Current Version \(2017\)](#)

OWASP TOP 10 (<https://owasp.org/www-project-top-ten/>)



OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

1. Broken Access Control(취약한 접근 통제)

개요

- 인증된 사용자라도 접근이 제한된 데이터나 기능에 접근할 수 있는 취약점
- 예: 사용자가 다른 계정의 데이터를 조회하거나, 관리자 기능을 수행할 수 있음

✂ 대응 방안

- 모든 요청에 대해 접근 권한 확인
- 최소 권한 원칙(Least Privilege) 적용
- 역할 기반 접근 제어(Role-Based Access Control, RBAC) 구현

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

2. Cryptographic Failures(암호화 실패)

개요

- 데이터 보호가 제대로 되지 않아 기밀 정보가 노출되는 취약점
- 예: 민감한 데이터를 평문(Plaintext)으로 저장하거나 전송

대응 방안

- HTTPS/TLS 사용하여 데이터 암호화
- 안전한 암호화 알고리즘(AES, RSA) 사용
- 비밀번호는 해시 및 솔트(Hashing & Salting) 적용

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

3. Injection(인젝션 공격)

개요

- 공격자가 악성 코드를 삽입하여 데이터베이스 조작 및 시스템 장악 가능
- 예: SQL Injection, XSS(Cross-Site Scripting), Command Injection

대응 방안

- 사용자 입력값을 검증하고 필터링
- SQL 쿼리에서는 Prepared Statement 및 ORM(Object-Relational Mapping) 사용
- 입력값을 실행하지 않고 안전하게 처리

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

4. Insecure Design(보안 설계 미흡)

개요

- 보안 요소를 고려하지 않은 시스템 설계로 인해 취약점이 발생
- 예: 비밀번호 없이 관리자 패널 접근 가능

대응 방안

- 보안 설계 원칙(Security by Design) 적용
- 위협 모델링(Threat Modeling) 수행
- 보안 설계를 코드에 반영하고 주기적으로 검토

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

5. Misconfiguration(보안 설정 오류)

개요

- 기본 설정값 유지, 디버그 모드 활성화 등으로 인해 발생하는 취약점
- 예: 관리자 패널의 기본 아이디/비밀번호 미변경

대응 방안

- 불필요한 기능 및 서비스 비활성화
- 보안 패치 및 업데이트 주기적 적용
- 환경 설정 파일의 접근 제한

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

6. Vulnerable and Outdated Components(취약하고 오래된 구성요소)

개요

- 오래된 라이브러리, 프레임워크, 플러그인을 사용하여 공격에 노출
- 예: 패치가 적용되지 않은 오픈소스 소프트웨어 사용

대응 방안

- 최신 버전의 라이브러리 및 프레임워크 유지
- 사용 중인 오픈소스 및 서드파티 모듈의 보안 이슈 확인
- 소프트웨어 구성 목록(SBOM, Software Bill of Materials) 관리

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

7. Identification and Authentication Failures(인증 및 세션 관리 취약점)

개요

- 약한 비밀번호, 세션 하이재킹 등의 문제로 인증이 우회될 가능성이 있는 취약점
- 예: 브루트 포스 공격(무작위 비밀번호 대입), JWT 토큰 유출

대응 방안

- 다중 요소 인증(MFA) 적용
- 안전한 세션 관리(토큰 만료 및 회수)
- 강력한 비밀번호 정책 적용 및 보호

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

8. Software and Data Integrity Failures(소프트웨어 및 데이터 무결성 실패)

개요

- 무결성을 검증하지 않은 코드 및 데이터로 인해 악성 코드가 실행될 가능성이 있는 취약점
- 예: 코드 서명 없는 업데이트 파일, 신뢰할 수 없는 CI/CD 파이프라인

대응 방안

- 코드 서명(Code Signing) 및 무결성 검증
- CI/CD 파이프라인 보안 강화
- 서드파티 구성 요소의 신뢰성 검토

OWASP TOP 10 2021(<https://owasp.org/www-project-top-ten/>)

9. Security Logging and Monitoring Failures(보안 로깅 및 모니터링 실패)

개요

- 보안 이벤트를 로깅하지 않거나 적절한 모니터링이 없어 공격을 탐지하지 못하는 취약점
- 예: 로그인 실패 기록 미비, 이상 트래픽 감지 불가

대응 방안

- 보안 이벤트 로깅 및 중앙화된 로그 관리
- SIEM(Security Information and Event Management) 도입
- 보안 인시던트 대응 체계 구축

OWASP TOP 10 2021 (<https://owasp.org/www-project-top-ten/>)

10. Server-Side Request Forgery(SSRF)

개요

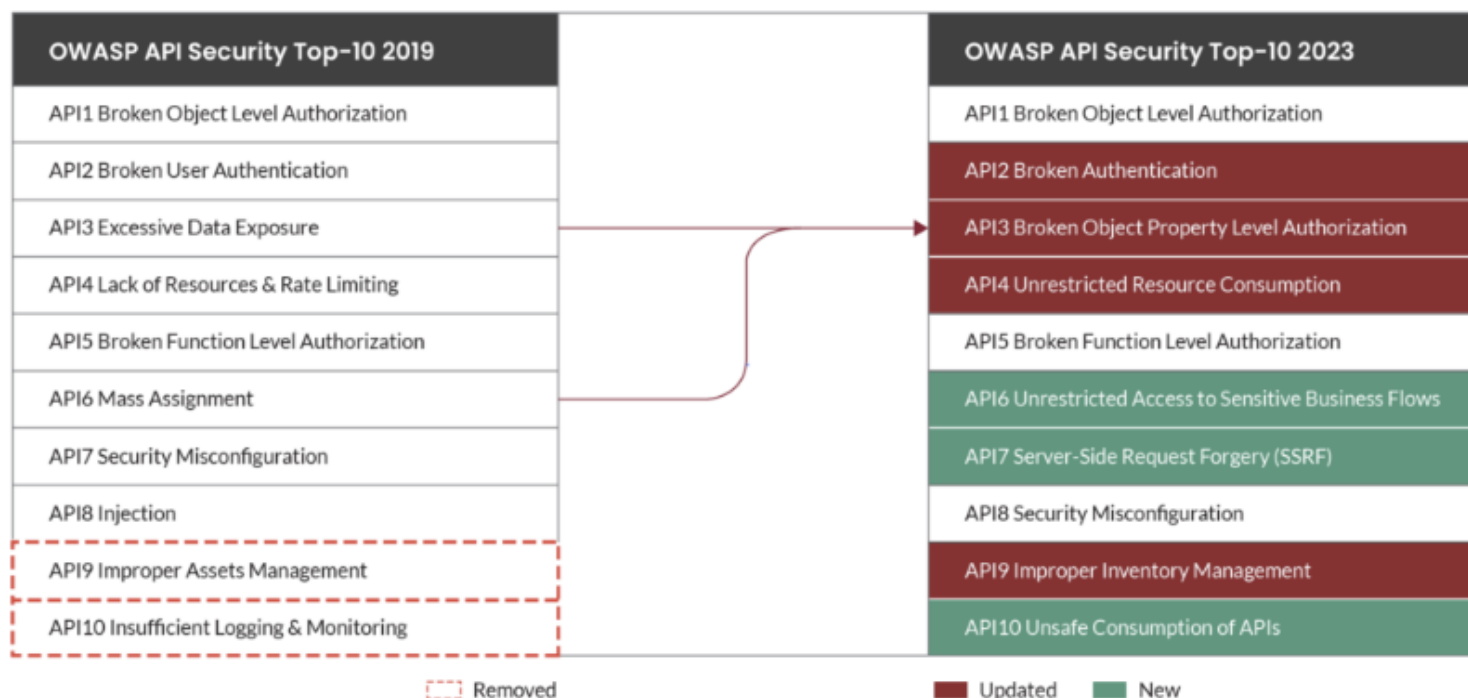
- 공격자가 서버를 이용해 내부 네트워크를 스캔하거나 외부 사이트를 공격하는 취약점
- 예: 웹 애플리케이션에서 내부 시스템의 민감한 데이터 요청 가능

대응 방안

- 외부 요청을 제한하고 허용 목록(Allowlist) 적용
- 입력값 검증 및 보안 헤더(Content Security Policy) 설정
- 네트워크 레벨에서 API 호출 제한

OWASP API Security Risk TOP 10

OWASP(Open Web Application Security Project)의 API Security Top 10은 API(Application Programming Interface)의 보안 취약점과 이에 대한 대응 방안을 정리한 리스트.



API는 웹 애플리케이션과 서비스 간의 데이터 교환을 가능하게 하지만,보안이 취약할 경우 심각한 보안 사고를 초래할 수 있다.

OWASP API Security Risk TOP 10 2023

1. Broken Object Level Authorization(객체 수준 권한 관리 실패)

개요

API 요청에서 사용자 권한을 제대로 검증하지 않아, 공격자가 다른 사용자의 데이터를 조회, 수정, 삭제할 수 있는 취약점

✂ 대응 방안

- 요청마다 인증 및 권한 검사를 수행
- 최소 권한 원칙(Least Privilege) 적용
- 강력한 ID 기반 접근 제어(Access Control) 정책 구현

OWASP API Security Risk TOP 10 2023

2. Broken Authentication(취약한 인증)

개요

API에서 인증 과정이 제대로 보호되지 않으면, 공격자가 불법적으로 인증을 우회하거나 계정을 탈취할 수 있다.

대응 방안

- 다중 요소 인증(MFA) 적용
- 보안이 강화된 인증 토큰 사용 (JWT, OAuth2)
- 인증 토큰의 만료 및 회수 정책 설정

OWASP API Security Risk TOP 10 2023

3. Broken Object Property Level Authorization(객체 속성 수준의 권한 관리 실패)

개요

API 응답에서 민감한 데이터가 과도하게 노출되거나, 허가되지 않은 사용자가 특정 속성을 수정할 수 있는 취약점

✂ 대응 방안

- API 응답에서 노출되는 데이터 최소화
- 사용자 입력 값에 대한 권한 검증 수행
- 클라이언트 측 검증이 아닌 서버 측 검증 필수

OWASP API Security Risk TOP 10 2023

4. Unrestricted Resource Consumption(제한 없는 리소스 소비)

개요

공격자가 API 요청을 과도하게 보내 서버의 CPU, 메모리, 네트워크를 소모시키는 취약점 (DDoS 공격 가능)

✂ 대응 방안:

- 요청 수 및 속도 제한(Rate Limiting) 적용
- API 호출에 대한 타임아웃 및 최대 크기 제한 설정
- 트래픽 이상 감지 및 자동 차단 설정

OWASP API Security Risk TOP 10 2023

5. Broken Function Level Authorization(기능 수준의 권한 관리 실패)

개요

공격자가 관리자 기능을 일반 사용자 권한으로 실행하거나, 권한이 없는 API 엔드포인트를 호출하는 취약점.

✂ 대응 방안

- 사용자 역할(Role-Based Access Control, RBAC) 적용
- 모든 기능에 대한 인증 및 권한 검증 수행
- 권한이 없는 기능 요청을 즉시 차단

OWASP API Security Risk TOP 10 2023

6. Unrestricted Access to Sensitive Business Flows(민감한 비즈니스 흐름에 대한 무제한 접근)

개요

API에서 인증 없이 중요한 프로세스를 실행할 수 있을 때 발생하는 취약점입니다.

예를 들어, OTP 인증 없이 비밀번호 재설정을 허용하는 경우

대응 방안

- 비즈니스 크리티컬 API에 강력한 인증 및 접근 제어 적용
- 사용자 입력 검증 및 워크플로우 기반 검증 강화
- 주요 프로세스에 대해 추가적인 보안 확인 적용

OWASP API Security Risk TOP 10

7. API7:2023 - Server Side Request Forgery (SSRF)

개요

공격자가 API를 통해 서버가 임의의 외부 URL을 요청하도록 조작할 수 있는 취약점입니다.
내부 네트워크 스캐닝 및 데이터 탈취에 악용될 수 있습니다.

대응 방안

- API에서 외부 요청을 차단하거나 허용 목록(Allowlist) 기반의 제한 적용
- URL 및 IP 주소 검증을 수행하여 내부 주소 접근 차단
- API에서 불필요한 외부 요청을 최소화

OWASP API Security Risk TOP 10 2023

8. Security Misconfiguration(보안 설정 오류)

개요

기본 설정값을 사용하거나, 디버그 모드를 활성화하는 등 보안 설정이 제대로 구성되지 않은 경우 발생하는 취약점

✂ 대응 방안

- 보안 정책을 수립하고 정기적인 보안 점검 수행
- API 서버 및 클라우드 환경에서 최소 권한 설정 적용
- 최신 보안 패치를 적용하고, 디버그 및 로그 설정을 보호

OWASP API Security Risk TOP 10 2023

9. Improper Inventory Management(잘못된 API 관리)

개요

API가 버전 관리되지 않거나, 오래된 API 엔드포인트가 유지되어 공격자가 악용할 수 있는 취약점.

✂ 대응 방안

- API 버전 관리(V1, V2 등) 및 폐기 정책 정의
- 오래된 API를 비활성화하고 최신 버전으로 업그레이드 유도
- API 문서화를 철저히 하여 불필요한 노출 방지

OWASP API Security Risk TOP 10 2023

10. Unsafe Consumption of APIs(안전하지 않은 API 소비)

개요

외부 API를 사용할 때 보안 검증 없이 데이터를 신뢰하면 발생하는 취약점.
예를 들어, API 응답을 검증하지 않아 악성 데이터를 받아들이는 경우.

✂ 대응 방안

- 외부 API 응답을 검증하고 신뢰할 수 있는 데이터만 처리
- API 호출 시 입력값 검증 적용 (JSON Schema, XML Validation 등)
- API 키 및 인증 토큰을 안전하게 관리

OWASP Mobile Risk TOP 10

OWASP(Open Worldwide Application Security Project)는 모바일 애플리케이션의 보안 취약점을 식별하고 대응하기 위해 OWASP Mobile Top 10 목록을 주기적으로 발표. 가장 최근의 2024년 버전에서는 모바일 애플리케이션에서 가장 중요한 보안 위험 10가지를 다음과 같이 정의하고 있다

Comparison Between 2016-2024		
OWASP-2016	OWASP-2024-Release	Comparison Between 2016-2024
M1: Improper Platform Usage	M1: Improper Credential Usage	New
M2: Insecure Data Storage	M2: Inadequate Supply Chain Security	New
M3: Insecure Communication	M3: Insecure Authentication / Authorization	Merged M4&M6 to M3
M4: Insecure Authentication	M4: Insufficient Input/Output Validation	New
M5: Insufficient Cryptography	M5: Insecure Communication	Moved from M3 to M5
M6: Insecure Authorization	M6: Inadequate Privacy Controls	New
M7: Client Code Quality	M7: Insufficient Binary Protections	Merged M8&M9 to M7
M8: Code Tampering	M8: Security Misconfiguration	Rewording [M10]
M9: Reverse Engineering	M9: Insecure Data Storage	Moved from M2 to M9
M10: Extraneous Functionality	M10: Insufficient Cryptography	Moved from M5 to M10



SW개발보안 국외기준

01 국외 개발보안 현황

02 OWASP TOP 10

03 CVE

04 CWE Top 25

CVE 취약점 DB활용(<http://cve.mitre.org>)

CVE(공통 취약점 및 노출, Common Vulnerabilities and Exposures)는 소프트웨어 및 하드웨어의 보안 취약점을 표준화하여 공개하는 시스템.

CVE는 보안 취약점을 표준화하고 추적하는 중요한 시스템이며, 기업과 개발자는 이를 활용하여 보안성 강화

특히 소프트웨어 개발자는 CVE 데이터를 활용하여 보안 취약점을 사전에 예방하고 신속하게 패치 적용

The screenshot shows the CVE website interface. At the top, there is a navigation bar with links: CVE List, CNAs, WGs, Board, About, and News & Blog. Below this is a search bar and a button labeled 'Go to for: CVE Scores CVE Info'. A black bar contains links: Search CVE List, Download CVE, Data Feeds, Request CVE IDs, and Update a CVE Entry. Below this bar, it says 'TOTAL CVE Entries: 136476'. The main content area has a paragraph explaining CVE: 'CVE® is a list of entries—each containing an identification number, a description, and at least one public reference—for publicly known cybersecurity vulnerabilities. CVE Entries are used in numerous cybersecurity products and services from around the world, including the U.S. National Vulnerability Database (NVD)'. Below this are three sections: 'Latest CVE News' with links to Xiaomi, GitLab, and OpenVPN being added as CNA; 'Become a CNA' with a world map showing CNA locations and links to learn more; and 'Newest CVE Entries' showing a tweet about CVE-2020-13758.

Latest CVE News

- Xiaomi Added as CVE Numbering Authority (CNA)
- GitLab Added as CVE Numbering Authority (CNA)
- OpenVPN Added as CVE Numbering Authority (CNA)

[More News >>](#)

CVE Blog

CVE Program Report for Calendar Year Q1-2020 Now Available

[CY Q1-2020 Milestones](#) - CVE Numbering Authorities (CNAs), CVE Board, CVE Working Groups, and more

[CY Q1-2020 Metrics](#) - CVE Entries and requests for CVE IDs from the CVE Program Root CNA

[Read More >>](#)

Become a CNA

CVE Numbering Authorities, or "CNAs," are essential to the CVE Program's success and every CVE Entry is added to the CVE List by a CNA.

Total CNAs: 128 | Total Countries: 21

[Learn How to Become a CNA >>>](#)

[Watch CNA Onboarding Videos >>](#)

Newest CVE Entries

Tweets by @CVEnew

CVE
@CVEnew
CVE-2020-13758
modules/security/classes/general.post_filter.php/post_filter.php in the Web Application Firewall in Bitrix24 through 20.0.950 allows XSS by placing %00 before the payload.
cve.mitre.org/cgi-bin/cvenam...

[Follow @CVEnew >>](#)

CVE 작동 방식

1. 취약점 발견
보안 연구원, 기업, 기관이 새로운 보안 취약점을 발견.
2. CVE 요청
CVE Numbering Authority(CNA)에 취약점 보고.
3. CVE ID 할당
MITRE가 검토 후 CVE ID 부여.
4. 공개 및 업데이트
취약점 세부 정보가 NVD 등에 등록되고, 보안 패치와 대응책 제공.

CVE 예제

1. CVE ID: CVE-2022-24086
2. 발견 일자: 2022년 2월 13일
3. 영향을 받는 시스템: Adobe Commerce 및 Magento Open Source 2.3.3 ~ 2.4.3-p1 버전
4. 취약점 설명: 입력 데이터에 대한 적절한 검증이 이루어지지 않아, 공격자가 특수하게 조작된 입력을 통해 SQL 쿼리를 조작하고, 이를 통해 데이터베이스에 임의의 코드를 실행하거나 민감한 정보를 탈취할 수 있는 취약점
5. 해결 방법: Adobe는 이 취약점을 해결하기 위해 보안 패치를 배포하였으며, 영향을 받는 사용자는 즉시 최신 버전으로 업데이트할 것을 권장

CVE 와 소프트웨어 개발보안

1. 보안 패치 적용
CVE 목록을 모니터링하여 최신 보안 패치를 적용.
2. 취약점 관리 및 평가
조직은 CVE를 기반으로 보안 리스크를 분석하고 대응 계획을 수립.
3. 자동화된 보안 검사 활용
CVE 데이터베이스를 활용하여 취약점 스캐너 및 보안 도구(CVE Scanners) 운영.



SW개발보안 국외기준

01 국외 개발보안 현황

02 OWASP TOP 10

03 CVE

04 CWE Top 25

CWE 취약점 DB활용(<http://cwe.mitre.org>)

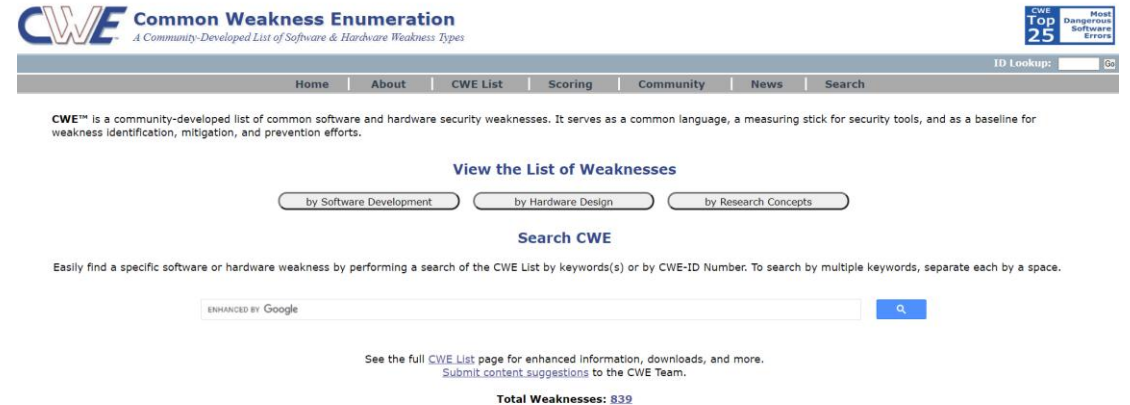
CWE(Common Weakness Enumeration)는 미 국토 안보부(The U.S. Department of Homeland Security)에서 관리하고 있으며, 소프트웨어와 하드웨어의 보안약점을 체계적으로 정리한 공개 목록

CWE 주요 목적

1. 소프트웨어 및 하드웨어 취약점 분류 및 표준화
2. 보안 취약점의 예방 및 완화를 위한 지침 제공
3. 보안 평가 및 코드 분석 도구 연계

CWE의 활용

1. 개발자의 보안 코딩 가이드라인 제공
2. 보안점검도구(정적분석, 동적분석)에서 CWE 목록 기반 취약점 탐지
3. OWASP, NIST, CVE 등과 연계하여 보안 개선에 활용



CWE 와 CVE의 차이점

구분	CWE	CVE
역할	보안약점(Weakness Type) 정의	특정 제품의 보안취약점(Vulnerability) 개별ID 부여
예시	CWE-89 SQL Injection CWE-79 XSS	CVE-2022-24086 특정제품의 SQL인젝션 취약점
적용범위	보안약점의 개념적 분류	실제 발생한 보안취약점(취약점 보고 및 패치 필요)

CWE TOP 25(https://cwe.mitre.org/top25/archive/2022/2022_cwe_top25.html)

CWE Top 25는 소프트웨어에서 가장 위험한 보안 약점 25가지를 선정한 목록으로, 개발자와 보안 전문가들이 우선적으로 대응해야 할 취약점을 제시. 이 목록은 MITRE에서 관리하며, National Vulnerability Database (NVD)의 데이터를 기반으로 작성됩니다.

! 선정방법

소프트웨어 약점의 발생빈도와 심각도를 기반으로 선정.

최근 2년간의 CVE 데이터를 분석하여 각 약점의 점수 산정 한 뒤, 각 약점의 보급률과 심각도를 고려한 공식에 따라 계산

$$\text{점수}(\text{CWE_X}) = \text{Fr}(\text{CWE_X}) * \text{Sv}(\text{CWE_X}) * 100$$

$$\text{Freq} = \{\text{NVD의 각 CWE_X'에 대한 개수}(\text{CWE_X}' \in \text{NVD})\}$$

$$\text{Fr}(\text{CWE_X}) = (\text{카운트}(\text{CWE_X} \in \text{NVD}) - \text{최소}(\text{Freq})) / (\text{최대}(\text{Freq}) - \text{최소}(\text{Freq}))$$

$$\text{Sv}(\text{CWE_X}) = (\text{average_CVSS_for_CWE_X} - \text{최소}(\text{CVSS})) / (\text{최대}(\text{CVSS}) - \text{최소}(\text{CVSS}))$$

CWE TOP 25 선정 목적 및 활용 방안

■ 주요목적

1. 취약점 인식: 가장 빈번하고 심각한 소프트웨어 약점을 강조하여 보안 사고 예방
2. 보안 강화: 개발 및 보안 팀이 우선적으로 해결해야 할 취약점을 파악하고 대응
3. 교육 자료: 보안 교육과 훈련에 활용되어 안전한 코딩과 설계 촉진

■ 활용 방안

1. 보안 우선순위 설정: 개발 및 보안 팀은 CWE Top 25를 참고하여 취약점 대응의 우선순위를 정하고,
제한된 자원을 효과적으로 활용
2. 보안 교육 자료로 활용: CWE Top 25는 보안 교육의 핵심 자료로 사용되어, 개발자들이 흔히 발생하는 취약점을
이해하고 예방하는 데 도움을 줌
3. 보안 도구와의 연계: 정적 분석 도구나 취약점 스캐너는 CWE Top 25를 기반으로 코드를 검사하여, 잠재적인 보안 약점을
자동으로 탐지하고 보고

2023 CWE TOP 25 (<https://cwe.mitre.org/top25/>)

순위	ID	Name	점수	악용 빈도	순위 변화
1	CWE-787	Out-of-bounds Write	63.72	70	0
2	CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	45.54	4	0
3	CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	34.27	6	0
4	CWE-416	Use After Free	16.71	44	+3
5	CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	15.65	23	+1
6	CWE-20	Improper Input Validation	15.50	35	-2
7	CWE-125	Out-of-bounds Read	14.60	2	-2
8	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	14.11	16	0
9	CWE-352	Cross-Site Request Forgery (CSRF)	11.73	0	0
10	CWE-434	Unrestricted Upload of File with Dangerous Type	10.41	5	0
11	CWE-862	Missing Authorization	6.90	0	+5
12	CWE-476	NULL Pointer Dereference	6.59	0	-1

2023 CWE TOP 25 (<https://cwe.mitre.org/top25/>)

순위	ID	Name	점수	악용 빈도	순위 변화
13	CWE-287	Improper Authentication	6.39	10	+1
14	CWE-190	Integer Overflow or Wraparound	5.89	4	-1
15	CWE-502	Deserialization of Untrusted Data	5.56	14	-3
16	CWE-77	Improper Neutralization of Special Elements used in a Command ('Command Injection')	4.95	4	+1
17	CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	4.75	7	+2
18	CWE-798	Use of Hard-coded Credentials	4.57	2	-3
19	CWE-918	Server-Side Request Forgery (SSRF)	4.56	16	+2
20	CWE-306	Missing Authentication for Critical Function	3.78	8	-2
21	CWE-362	Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')	3.53	8	+1
22	CWE-269	Improper Privilege Management	3.31	5	+7
23	CWE-94	Improper Control of Generation of Code ('Code Injection')	3.30	6	+2
24	CWE-863	Incorrect Authorization	3.16	0	+4
25	CWE-276	Incorrect Default Permissions	3.16	0	-5



요약 정리

- ✓ 국외 소프트웨어 개발보안을 위한 지속적인 활동을 학습함.
- ✓ OWASP TOP 10 을 활용하여 웹 애플리케이션을 이용한 서비스 시 반드시 고려해야 하는 보안 이슈들을 학습함.
- ✓ 보안취약점 데이터베이스인 CVE 리스트의 용도를 이해하고 개발단계에 보안설계시 활용하는 방안을 학습함.
- ✓ 보안 약점 데이터베이스인 CWE 용도를 이해하고, CWE TOP 25 목록을 개발단계에 활용하여 소프트웨어 보안을 강화하는 체크리스트로 활용하는 것을 학습함.



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [KISA] 클라우드서비스(SaaS)_보안인증기분_해설서(2023.3)
- [KISA] 주요정보통신기반시설 기술적 취약점 분석 평가 상세 가이드(2021.03)
- [오픈이지북스] 실무에 바로 적용하는 해킹 방어를 위한 JAVA 시큐어코딩
- [홍릉과학출판사] 소프트웨어 개발 보안 실무 - 시큐어 코딩 원리와 실제
- [secu BOOK] 웹 해킹과 시큐어코딩 탐지/수정 실습가이드
- [에이콘출판사] 보안 위협 모델링 Threat Modeling - 위협 식별과 대응을 위한 소프트웨어 설계
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- [위키북스] 웹 애플리케이션 보안 완벽 가이드 - 체계적으로 배우는 안전한 웹 애플리케이션 제작 기법
- [한빛미디어] 웹 애플리케이션 보안 - 정찰, 공격, 방어 세 단계로 배우는 웹 애플리케이션 보안의 모든 것
- [한빛미디어] 웹 해킹 & 보안 완벽 가이드 - 웹 애플리케이션 보안 취약점을 겨냥한 공격과 방어
- OWASP - <https://owasp.org/>
- CVE - <https://cve.mitre.org/>
- CWE - <https://cwe.mitre.org/>
- SEI CERT Coding Standards - <https://wiki.sei.cmu.edu/confluence/display/seccode>

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large sphere with a gradient in the top left, a smaller sphere with diagonal stripes in the top right, and another sphere with horizontal stripes in the bottom left. Several network diagrams, consisting of interconnected nodes and lines, are scattered across the image. There are also solid-colored rectangles and trapezoids in different shades of blue. The central text is a large, bold, white Korean phrase.

감사합니다.



퀴즈

1. 다음 중 '취약한 접근 통제' 취약점에 대한 설명이 맞는 것은?

- 1) 인증된 사용자가 접근이 제한된 데이터나 기능에 접근 가능
- 2) 손쉬운 암호 설정으로 인해 부루트포스 공격 가능
- 3) 없는 주소를 입력하였을 때 에러 메시지와 함께 서버 정보 노출
- 4) 틀린 암호를 무제한으로 시도 가능

2. 다음 중 '인젝션 공격'에 대한 설명으로 틀린 것은?

- 1) 악성 코드를 삽입하는 공격이다.
- 2) 사용자 입력값을 검증하고 필터링하면 방어할 수 있다.
- 3) 커맨드 인젝션 방어를 위해 Prepared Statement를 사용해야 한다.
- 4) 주로 사용자의 입력값을 그대로 파라미터로 사용할 때 발생한다.

3. 다음 중 CVE와 CWE에 대해서 잘못 이야기한 것은?

- 1) CVE는 소프트웨어와 하드웨어 보안 취약점을 공개한 시스템이다.
- 2) 보안 연구원, 기업, 기관이 발견한 취약점은 CNA에 보고된다.
- 3) CWE Top 25는 보안 취약점 중 가장 위험한 25가지를 선정한 목록이다.
- 4) 특정제품에서 발견된 취약점은 CVE 목록에서 찾을 수 있다.



퀴즈 정답

1. 다음 중 '취약한 접근 통제' 취약점에 대한 설명이 맞는 것은?

1) 인증된 사용자가 접근이 제한된 데이터나 기능에 접근 가능

취약한 접근 통제 취약점은 적절한 인가 처리가 이루어지지 않아서 중요한 리소스 또는 기능이 권한 없는 사용자에게 노출될 수 있는 취약점을 말합니다.

2. 다음 중 '인젝션 공격'에 대한 설명으로 틀린 것은?

3) 커맨드 인젝션 방어를 위해 Prepared Statement를 사용해야 한다.

Prepared Statement 는 데이터베이스를 조작할 때 쿼리를 만드는 방법이며, SQL 인젝션을 예방할 수 있습니다.

3. 다음 중 CVE와 CWE에 대해서 잘못 이야기한 것은?

3) CWE Top 25는 보안 취약점 중 가장 위험한 25가지를 선정한 목록이다.

CWE는 보안 약점 목록을 말하며, 보안 취약점 목록은 CVE 입니다.